



Update the title of the document to give an accurate description and summary/tldr at the top

Here is the updated document with a revised title and TL;DR summary at the top:

International Data Transfers to Third Countries: Legal Basis, Schrems II Obligations, and anDREa Compliance Measures

Last reviewed: 2026-02-22

Last updated: 2026-02-22

Previous version: [Privacy Shield / Schrems II](#)

TL;DR

The EU-US Privacy Shield is dead. The CJEU invalidated it in July 2020 (Schrems II). A replacement — the EU-US Data Privacy Framework (DPF) — was adopted in July 2023 but remains legally contested.

Standard Contractual Clauses (SCCs) are the primary transfer mechanism you should rely on. They are only valid when accompanied by a documented Transfer Impact Assessment (TIA) and, where gaps are found, supplementary technical, contractual, and organizational measures.

As a controller, you must conduct and document TIAs, execute SCCs with all non-EU processors, maintain your RoPA, and update your privacy notices.

anDREa (your processor) supports your compliance by: deploying all resources in EU/EEA Azure data centers; leveraging the Microsoft EU Data Boundary (completed February 2025); applying encryption, RBAC, MFA, and logging; and relying on 2021-model SCCs with all sub-processors.

Key risk to monitor: a future "Schrems III" challenge to the DPF adequacy decision is anticipated. Ensure your SCCs and TIAs are always kept current and documented regardless of adequacy status.

Introduction

The **EU-US Privacy Shield** was a framework for regulating transatlantic exchanges of personal data for commercial purposes between the European Union and the United States. One of its purposes was to enable US companies to more easily receive personal data from EU entities under EU privacy laws meant to protect European Union citizens. The EU-US Privacy Shield was a replacement for the **International Safe Harbor Privacy Principles**, which were declared invalid by the European Court of Justice in October 2015 (Schrems I).

On **16 July 2020**, the Court of Justice of the European Union (CJEU) declared the EU-US Privacy Shield **invalid** in its landmark judgment in case **C-311/18** (*Data Protection Commissioner v Facebook Ireland Ltd, Maximillian Schrems*, commonly known as **Schrems II**). The Court found that US surveillance laws (notably Section 702 FISA and Executive Order 12333) permitted disproportionate access to personal data transferred from the EU and did not provide an essentially equivalent level of protection to that guaranteed by the EU Charter of Fundamental Rights (Articles 7 and 8).

CJEU Schrems II judgment: <https://curia.europa.eu/jcms/upload/docs/application/pdf/2020-07/cp200091en.pdf>

Current Legal Landscape

EU-US Data Privacy Framework (2023)

On **10 July 2023**, the European Commission adopted an **adequacy decision** for the **EU-US Data Privacy Framework (DPF)**, which entered into force immediately. Under this decision, personal data may be transferred from the EU to US companies that have **self-certified** their participation in the DPF without the need for additional transfer mechanisms.

The DPF includes binding safeguards designed to address the concerns raised in Schrems II:

- Limitations on US intelligence agencies' access to EU data beyond what is "necessary and proportionate"
- An independent **Data Protection Review Court (DPRC)** providing individuals with an effective remedy for challenges to surveillance measures

European Commission adequacy decision (DPF): https://ec.europa.eu/commission/presscorner/detail/en/ip_23_3721

US DPF official website: <https://www.dataprivacyframework.gov/Program-Overview>

Legal status: On 3 September 2025, the EU General Court **dismissed** the first legal challenge to the DPF adequacy decision, upholding its validity. However, the DPF remains politically and legally contested, and an appeal to the CJEU is anticipated.

Standard Contractual Clauses (SCCs)

The CJEU's Schrems II judgment **upheld the validity** of **Standard Contractual Clauses (SCCs)** as a legal mechanism for international data transfers, provided they are accompanied by appropriate safeguards.

On **4 June 2021**, the European Commission adopted **modernised Standard Contractual Clauses** under the GDPR (Commission Implementing Decision (EU) 2021/914). These SCCs replaced the previous three sets adopted under Directive 95/46/EC and feature a modular structure to accommodate different transfer scenarios:

- **Module 1:** Controller to Controller
- **Module 2:** Controller to Processor
- **Module 3:** Processor to Processor
- **Module 4:** Processor to Controller

European Commission SCCs (2021): https://commission.europa.eu/law/law-topic/data-protection/international-dimension-data-protection/standard-contractual-clauses-scc_en

Commission Q&A on SCCs: https://commission.europa.eu/law/law-topic/data-protection/international-dimension-data-protection/new-standard-contractual-clauses-questions-and-answers_en

Requirements for Data Transfers under Schrems II

Transfer Impact Assessment (TIA)

Following Schrems II, **controllers and processors** transferring personal data to third countries using SCCs or other Article 46 GDPR transfer tools **must**:

1. **Conduct and document a Transfer Impact Assessment (TIA)** to evaluate whether the destination country's laws and practices provide an essentially equivalent level of protection to EU standards
2. **Assess the impact of surveillance laws** in the third country, applying the **European Essential Guarantees** framework developed by the EDPB
3. **Identify and implement supplementary measures** (technical, contractual, or organizational) if the assessment reveals protection gaps
4. **Document the assessment and supplementary measures** and make this documentation available to competent supervisory authorities upon request
5. **Monitor and periodically re-assess** transfers to account for changes in third-country law or practices

EDPB Recommendations 01/2020 on supplementary measures: https://www.edpb.europa.eu/system/files/2021-06/edpb_recommendations_202001vo.2.0_supplementarymeasurestransferstools_en.pdf

EDPB Recommendations 02/2020 on European Essential Guarantees: <https://edpb.europa.eu/our-work-tools/our-documents/recommendations/recommendations-022020-european-essent>

European Essential Guarantees

The EDPB's **Recommendations 02/2020** outline four essential guarantees that surveillance measures in third countries must respect to be considered essentially equivalent to EU standards:

1. **Processing based on clear, precise, and accessible rules**
2. **Necessity and proportionality** demonstrated with regard to legitimate objectives
3. **Independent oversight mechanism**
4. **Effective remedies** available to individuals

Supplementary Measures

Where the TIA reveals gaps in protection, data exporters must implement **supplementary measures** to bring protection to an essentially equivalent level. These may include:

Technical measures:

- End-to-end encryption with keys held exclusively within the EU/EEA
- Pseudonymization or anonymization before transfer
- Multi-party computation or confidential computing technologies

Contractual measures:

- Transparency obligations regarding government access requests
- Notification obligations (where legally permitted)
- Contractual prohibitions on disclosure beyond specified purposes

Organizational measures:

- Policies and procedures limiting access to transferred data
- Staff training on data protection and transfer limitations
- Audit and monitoring procedures

EDPB Recommendations 01/2020 (Annex 2) provides a non-exhaustive list of example supplementary measures.

What anDREa Does to Support Schrems II Compliance

anDREa acts as a **processor** under the GDPR. Your organization (the **controller**) remains responsible for determining the lawfulness of data transfers, selecting appropriate transfer mechanisms, and conducting Transfer Impact Assessments. anDREa provides the following technical and organizational measures to support your compliance:

Data Locality and EU Data Boundary

- **EU/EEA data residency:** By default, all resources—virtual machines, storage, and databases—are deployed in **Microsoft Azure data centers located within the EU/EEA** (primarily Amsterdam, Netherlands).
- **Microsoft EU Data Boundary:** anDREa leverages Microsoft Azure services covered by the **Microsoft EU Data Boundary**, which was **completed in February 2025** (Phase 3). The EU Data Boundary ensures that:
 - **Customer data** for Microsoft 365, Dynamics 365, Power Platform, and most Azure services is **stored and processed within the EU and EFTA regions**
 - **Pseudonymized personal data** remains within the EU/EFTA regions
 - **Professional services data** (technical support logs, case notes) from support interactions is stored within the EU/EFTA regions

Microsoft EU Data Boundary announcement: <https://blogs.microsoft.com/on-the-issues/2025/02/26/microsoft-completes-landmark-eu-data-boundary-offering-enhanced-data-residency-and-transparency/>

Microsoft EU Data Boundary documentation: <https://learn.microsoft.com/en-us/privacy/eudb/eu-data-boundary-learn>

Technical Safeguards (Supplementary Measures)

- **Encryption at rest and in transit:** All Workspace data is encrypted using strong, industry-standard algorithms (AES-256 for data at rest; TLS 1.2+ for data in transit). Encryption keys are managed by Microsoft Azure Key Vault within the EU region.
- **Role-Based Access Control (RBAC):** Each Workspace is protected by granular access controls. Users are assigned the minimum necessary privileges.
- **Multi-Factor Authentication (MFA):** All Workspace access requires two-factor authentication, significantly reducing the risk of unauthorized access.
- **Logical isolation:** Each Workspace is logically isolated from other tenants, preventing cross-tenant data leakage.
- **Data minimization and pseudonymization:** Where feasible, anDREa supports pseudonymization and minimization techniques to limit exposure of personal data.

Organizational Safeguards

- **Comprehensive logging and monitoring:** Extensive logging of access events, including failed authentication attempts and privilege escalations. Logs are retained and monitored for anomalous activity.
- **Staff training and policies:** anDREa personnel are trained on GDPR principles, data protection obligations, and procedures for handling government access requests.
- **Incident response procedures:** Documented procedures for detecting, investigating, and responding to data breaches or unlawful access attempts.

- **Transparency and notification:** anDREa will notify customers of government access requests to the extent legally permitted under applicable law.

Standard Contractual Clauses

anDREa relies on the **European Commission's 2021 Standard Contractual Clauses** for any sub-processors or service providers located outside the EU/EEA. These SCCs include:

- Appropriate module selection (Module 2: Controller to Processor, or Module 3: Processor to Processor)
- Completed annexes specifying data categories, processing purposes, retention periods, and technical/organizational measures
- Obligations on sub-processors to implement supplementary measures where necessary

Microsoft statement on SCCs: <https://blogs.microsoft.com/eupolicy/2020/07/16/assuring-customers-about-cross-border-data-flows/>

Division of Responsibilities (Controller vs Processor)

Controller Responsibilities (Your Organization)

As the **data controller**, you are responsible for:

- Determining the **lawful basis** for processing personal data under Article 6 GDPR
- Determining the **lawful basis for international transfers** (adequacy decision, SCCs, BCRs, derogations under Article 49 GDPR)
- **Conducting and documenting Transfer Impact Assessments (TIAs)** for any transfers to third countries, including onward transfers by sub-processors
- **Selecting processors** that provide sufficient guarantees to implement appropriate technical and organizational measures
- **Concluding Data Processing Agreements (DPAs)** and Standard Contractual Clauses with processors and sub-processors
- **Informing data subjects** of international transfers in your privacy notices (Articles 13/14 GDPR)
- **Maintaining Records of Processing Activities (RoPA)** documenting transfers (Article 30 GDPR)
- **Conducting Data Protection Impact Assessments (DPIAs)** where processing involves high risks (Article 35 GDPR), including for certain international transfers

Processor Responsibilities (anDREa)

As the **data processor**, anDREa is responsible for:

- Processing personal data **only on documented instructions** from the controller
- **Assisting the controller** with Transfer Impact Assessments by providing technical and organizational measure documentation, sub-processor lists, data flow descriptions, and information on third-country laws potentially affecting data protection
- **Implementing appropriate technical and organizational measures** to ensure data security (Article 32 GDPR)
- **Engaging sub-processors** only with prior written authorization and under SCCs/DPAs with equivalent obligations
- **Assisting with data subject rights requests** and DPIAs as required by the controller
- **Notifying the controller** of personal data breaches without undue delay (Article 33 GDPR)
- **Deleting or returning personal data** at the end of the provision of services

Practical Recommendations for Controllers

1. Data Processing Agreements and SCCs

- Ensure signed DPAs are in place with anDREa and all other processors.
- Execute Standard Contractual Clauses (2021 version) with all processors located outside the EU/EEA.
- Review SCCs annexes carefully to ensure data categories, processing purposes, retention periods, and technical measures are accurately documented.

2. Transfer Impact Assessments

- Conduct and document TIAs for all relevant transfers, including to Microsoft Azure (given potential sub-processor or support access from third countries).
- Apply the European Essential Guarantees framework to assess third-country surveillance laws.
- Identify and implement supplementary measures and retain TIA documentation for supervisory authority review.

3. Workspace Access and Role Management

- Ensure processing agreements are in place with all external collaborators before enrolling them in a Workspace.
- Carefully consider granting roles other than "Member" to individuals not 100% based in the EU/EEA, subject to third-country laws (e.g., US CLOUD Act), or employed by entities with headquarters outside the EU/EEA.
- Regularly review and audit user roles and access logs.

4. Records of Processing Activities (RoPA)

Document all transfers in your Article 30 RoPA, including categories of personal data, recipients, countries of destination, transfer mechanisms, supplementary measures, and TIA outcomes.

5. Monitoring and Periodic Review

- Periodically re-assess transfers to account for changes in third-country laws, sub-processor practices, or EDPB guidance.
- Update TIAs and supplementary measures as necessary. Monitor any potential "Schrems III" challenge to the DPF adequacy decision.

Key Resources and Official Links

Source	Link
CJEU Schrems II (C-311/18)	https://curia.europa.eu/jcms/upload/docs/application/pdf/2020-07/cp200091en.pdf
EU-US DPF adequacy decision	https://ec.europa.eu/commission/presscorner/detail/en/ip_23_3721
Standard Contractual Clauses (2021)	https://commission.europa.eu/law/law-topic/data-protection/international-dimension-data-protection/standard-contractual-clauses-scc_en
SCCs Q&A	https://commission.europa.eu/law/law-topic/data-protection/international-dimension-data-protection/new-standard-contractual-clauses-questions-and-answers_en
EDPB Recommendations 01/2020	https://www.edpb.europa.eu/system/files/2021-06/edpb_recommendations_202001vo.2.0_supplementarymeasurestransferstools_en.pdf
EDPB Recommendations 02/2020	https://edpb.europa.eu/our-work-tools/our-documents/recommendations/recommendations-022020-european-essential-guarantees_en
US DPF official website	https://www.dataprivacyframework.gov/Program-Overview
Microsoft EU Data Boundary (Feb 2025)	https://blogs.microsoft.com/on-the-issues/2025/02/26/microsoft-completes-landmark-eu-data-boundary-offering-enhanced-data-residency-and-transparency/
Microsoft EU Data Boundary docs	https://learn.microsoft.com/en-us/privacy/eudb/eu-data-boundary-learn
Microsoft SCCs commitment	https://blogs.microsoft.com/eupolicy/2020/07/16/assuring-customers-about-cross-border-data-flows/
CNIL TIA practical guide	https://www.cnil.fr/sites/cnil/files/2024-01/draft_practical_guide_transfer_impact_assessment.pdf
GDPR full text	https://gdpr-info.eu/

For questions or further information, please contact your anDREa Data Protection Officer or consult your legal counsel.

